



UNIVERSIDAD TECNOLÓGICA DE TEHUACÁN

INGENIERÍA EN DESARROLLO Y GESTION DE SOFTWARE

ASIGNATURA: DESARROLLO WEB PROFESIONAL

8º CUATRIMESTRE GRUPO “A”

RECUPERACION DE CONTRASEÑAS

PROFR. JOSE MIGUEL CARRERA PACHECHO

LILIA HERNÁNDEZ TUN

¿Qué es un token de recuperación?

Es una **credencial temporal y única** (generalmente una cadena alfanumérica aleatoria o un JWT) que el sistema genera cuando un usuario solicita restablecer su contraseña.

- **Cómo funciona:** Se envía a través de un canal secundario (como el correo electrónico). Al hacer clic en el enlace que contiene el token, el sistema valida que sea auténtico, que pertenezca al usuario y que aún sea válido.
- **Para qué sirve:** Sirve para autenticar la identidad del usuario de manera excepcional, permitiéndole acceder a una ruta protegida donde puede definir una nueva contraseña sin conocer la anterior.

¿Por qué deben expirar los tokens?

La expiración es una medida crítica de seguridad por varias razones:

- **Limitar la ventana de exposición:** Si un token es interceptado por un atacante, solo podrá usarlo durante un tiempo limitado (ej. 15 minutos).
- **Control de revocación:** Obliga al sistema a re-validar el estado del usuario periódicamente.
- **Higiene de datos:** Evita que enlaces antiguos en bandejas de entrada queden como "puertas abiertas" permanentes.

¿Qué ataques existen en flujos de recuperación?

Los flujos de recuperación son de los puntos más vulnerables. Algunos ataques comunes son:

- **Enumeración de usuarios:** Cuando el sistema revela si un correo existe o no (ej. "Ese correo no está registrado").
- **Fuerza bruta:** Intentar adivinar tokens si estos son cortos o predecibles.
- **Token Leakage (Fuga de token):** Si el token se envía por canales no cifrados (HTTP) o si aparece en los logs del servidor.

- **Envenenamiento de host (Host Header Injection):** Cambiar el dominio del enlace de recuperación para que el token se envíe a un servidor controlado por el atacante.

¿Cómo se diseña un flujo accesible para recuperación de acceso?

ara equilibrar la seguridad con una buena experiencia de usuario (UX) y accesibilidad:

- **Mensajes neutros:** Usar siempre: *"Si tu cuenta existe, recibirás un correo"*. Esto evita la enumeración.
- **Rutas dinámicas:** Implementar rutas en el frontend (como en Next.js) que capturen el token desde la URL (/recuperar/[token]) para procesarlo de forma limpia.
- **Accesibilidad (A11y):** Los formularios deben tener etiquetas claras, manejo de errores visible para lectores de pantalla y contraste adecuado.
- **Seguridad invisible:** Implementar **rotación de tokens** (invalidar el token viejo en cuanto se use) y asegurar que el token sea de un solo uso.

Diseñar e implementar flujo de recuperación y solicitud, validación y cambio de contraseña.



